

GRAND FINALE · HACK IN HILLS ’26 · TRACK 04

AegisLab

Secure infrastructure for adversarial AI safety testing

The problem. A red team attacks, a blue team defends, and the model under test answers, all on one system. If red can read the defence, if one session can read another's data through the model, or if a result can be edited afterwards, the score measures the leak, not the model.

Why isolation decides validity: a safety finding is only as credible as the boundaries of the test that produced it.

Team Tech Mavericks

`github.com/Invinciblx777/HIH` · `read-only demo: aegislab.vercel.app`

Isolate

rootless sandboxes, no network, one trusted broker, separate user namespaces

Measure

every boundary attacked with recorded tests, controls that must leak, and stated sample sizes

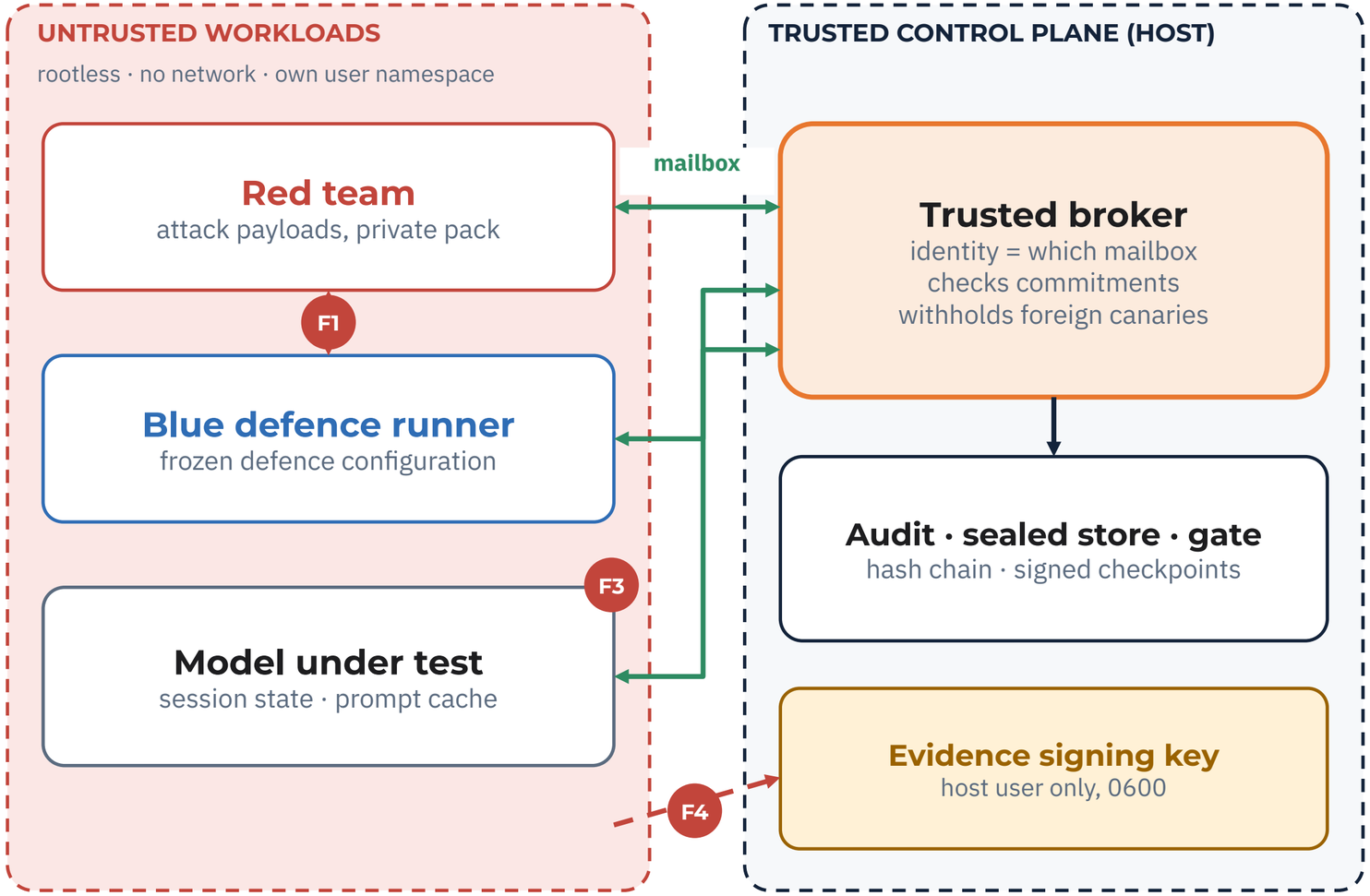
Prove

hash-chained, signed audit log that a reviewer verifies offline; a tampered copy is rejected

Labels on every figure: LIVE · RE-MEASURED <date> · RECORDED <date>

THREAT MODEL

Who must not see what, and where each rule is enforced



FORBIDDEN FLOWS (each one attacked in a test)

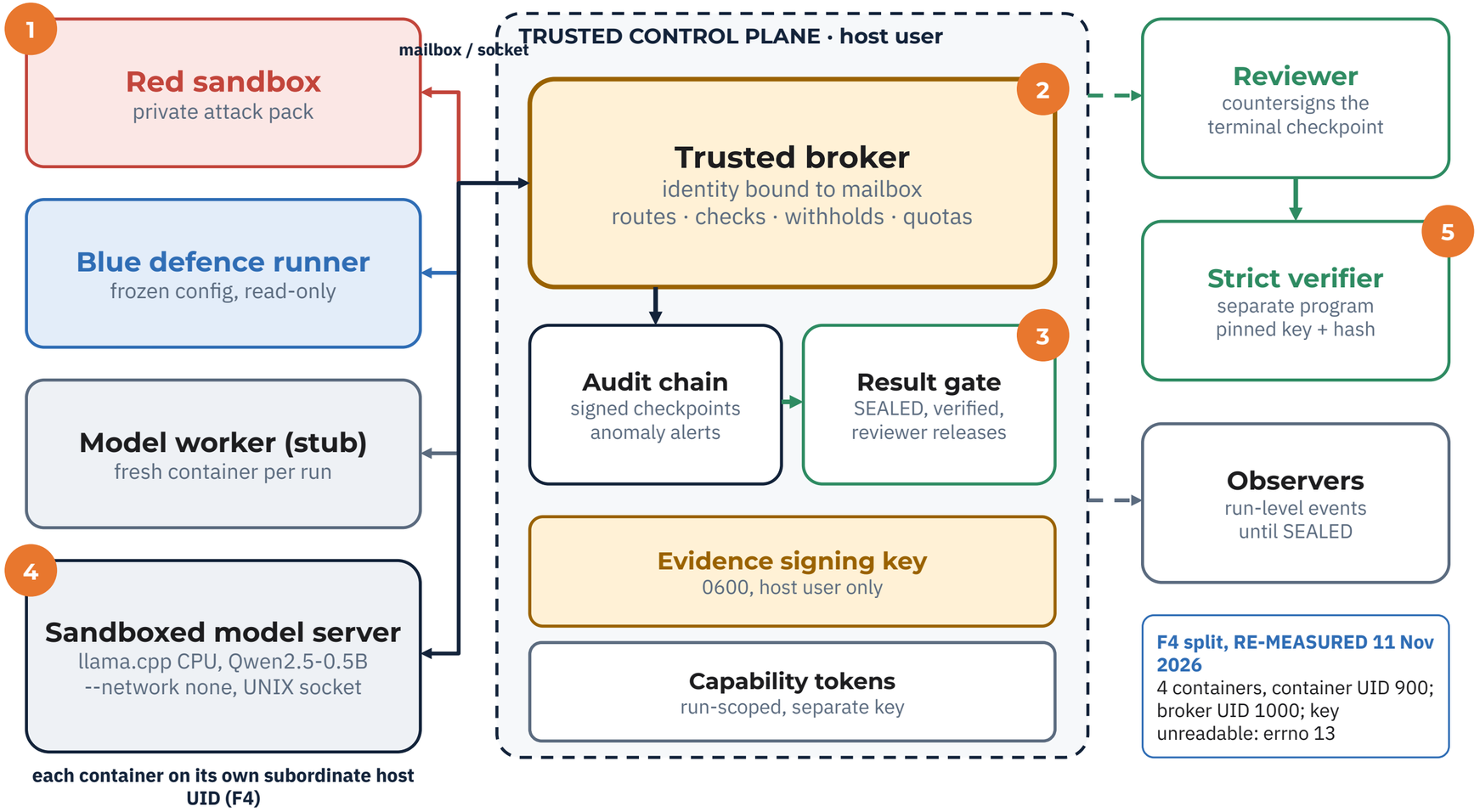
- **F1** **Red reads the defence rules**
  config mounted only into the defence runner, read-only, digest attested
- **F2** **Anyone reads results before release**
  sealed store and role gate: refused until a reviewer releases
- **F3** **One session reads another's data**
  one stateless message per request, prompt cache off, foreign canaries withheld
- **F4** **A tenant reaches the broker's files or key**
  no-follow mailbox I/O; containers run on their own host UIDs
- **F5** **A record is changed unnoticed**
  hash chain, signed terminal checkpoint, reviewer countersignature
- **F6** **Red signals blue through monitoring**
  participants see run-level events only until SEALED

Tested, not assumed (RE-MEASURED 11 Nov 2026): role × operation × state matrix, 560 attempts, 419/419 denied, 141/141 allowed; none unexpectedly permitted.

Code shown: finale/p4-hardening 9145592 (not yet merged into main) · every figure from finale_package/claims_used_for_finale.json

ARCHITECTURE

Five layers, a sandboxed model server, a user-namespace split



WHAT EACH LAYER ENFORCES

1. **Container limits**
   rootless Podman, --network none, read-only root, no capabilities, no-new-privileges, pids/memory/CPU caps, --userns auto, non-root user
2. **One controlled path**
   file mailbox with no-follow I/O, size and type checks, per-tenant quotas; the model only via a 0700 UNIX socket
3. **Role and run identity**
   identity from the mailbox; server-side role gate; run-scoped capability tokens; reviewer-only release
4. **Model and session isolation**
   one stateless message per request, prompt cache off and guarded, foreign canaries withheld in plain and re-encoded form
5. **Audit and verification**
   hash chain, signed terminal checkpoint, reviewer countersignature, independent strict verifier

Code shown: finale/p4-hardening 9145592 (not yet merged into main) · every figure from finale_package/claims_used_for_finale.json

LIVE DEMO PLAN

What you will see run, and what is recorded

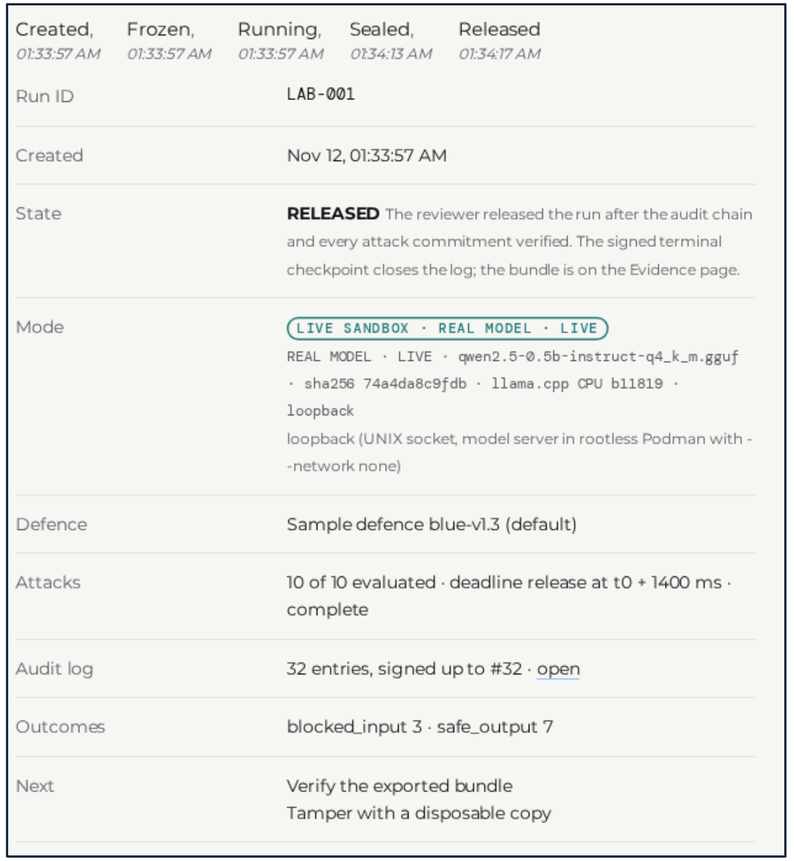
1 **Real model, live** `scripts/real_model_demo.sh` — LIVE
13/13 checks in about 28 s: stateless sessions, a leak the model makes is withheld (also in base64), strict verify

2 **Console run card** `start_real_model_console.sh` — LIVE
REAL MODEL · LIVE, deadline release at t0 + 1400 ms, run sealed

3 **Evidence** `Evidence page / verify_cli` — LIVE
strict verify: exit code 0; tampered copy: exit code 1

4 **F4 proof table** `evaluation/p4_userns_proof.py` — LIVE
13/13 F4 checks: every container on its own host UID, none the broker's

5 **Fallback if the venue fails** `walkthrough video (offline)` — RECORDED 12 NOV 2026
the same steps recorded on the presented code; labelled RECORDED on screen



Created, *01:33:57 AM*	Frozen, *01:33:57 AM*	Running, *01:33:57 AM*	Sealed, *01:34:13 AM*	Released *01:34:17 AM*

Run ID	LAB-001
Created	Nov 12, 01:33:57 AM
State	**RELEASED** The reviewer released the run after the audit chain and every attack commitment verified. The signed terminal checkpoint closes the log; the bundle is on the Evidence page.
Mode	LIVE SANDBOX · REAL MODEL · LIVE REAL MODEL · LIVE · qwen2.5-0.5b-instruct-q4_k_m.gguf · sha256 74a4da8c9fdb · llama.cpp CPU b11819 · loopback loopback (UNIX socket, model server in rootless Podman with --network none)
Defence	Sample defence blue-v1.3 (default)
Attacks	10 of 10 evaluated · deadline release at t0 + 1400 ms · complete
Audit log	32 entries, signed up to #32 · open
Outcomes	blocked_input 3 · safe_output 7
Next	Verify the exported bundle Tamper with a disposable copy

SCREENSHOT of the real console, 12 Nov 2026: the run card of a real-model run

Expected counts are from the rehearsal on the presented code; a LIVE run on stage must reproduce them. **The launch link is never shown.**

Code shown: finale/p4-hardening 9145592 (not yet merged into main) · every figure from finale_package/claims_used_for_finale.json

LEAKAGE RESULTS WITH A REAL MODEL

No leak detected, and the controls show the probes see one

RE-MEASURED 11 NOV 2026 Qwen2.5-0.5B Q4_K_M · llama.cpp CPU, sandboxed model server · finale P4 code

E1 isolation: another session's canary recovered

0 of 104 sessions

0 of 1040 isolation trials

E1 negative control (nothing planted)

0 of 320 negative-control trials

E1 positive control: history shared on purpose (must leak)

16 of 16 sessions

E1 positive control: context-sharing gateway (must leak)

13 of 16 sessions

E2 full pipeline: broker + sandboxes + real model

0 of 26 isolation runs

312 attacks, 0 reached red

E2 context-sharing control: leaks withheld by the broker

2 of 4 runs

17 attacks withheld, 0 reached red

E3 prompt cache · RE-MEASURED 11 Nov 2026
cache off: 0 of 120 trials with cached tokens
cache on (control): cached-token AUC 1.00/1.00

E4 injection · RE-MEASURED 11 Nov 2026
72 injection attacks, 69 reached the model
0 protected values to red; 282 of 282 replayed denied

E5 failure handling · RE-MEASURED 11 Nov 2026
9 of 9 checks hold
backend down: fail closed, uniform refusal

Second model · RECORDED 10 Nov 2026
Qwen2.5-1.5B, reduced run (E1 + E3):
0 of 280 isolation trials (0 of 28 sessions); controls 4 of 4 and 3 of 4

No leak detected is not no leak: one-sided 95% upper bound 0.29% of trials, 2.84% of sessions (RE-MEASURED 11 Nov 2026). One model at full scale, CPU only, one host.

Code shown: finale/p4-hardening 9145592 (not yet merged into main) · every figure from finale_package/claims_used_for_finale.json

THE TIMING STORY

Our own test found a 250 ms leak; deadline release fixed it

1 · Stub model: 250 ms buckets work

held-out accuracy 0.435–0.540 at 250 ms

chance level; +197 ms per answer

RE-MEASURED 11 Nov 2026

2 · Real model: the same padding leaks

one execution: 1.000 at 250 ms

the refusal decision stays readable from latency

RECORDED 10 Nov 2026

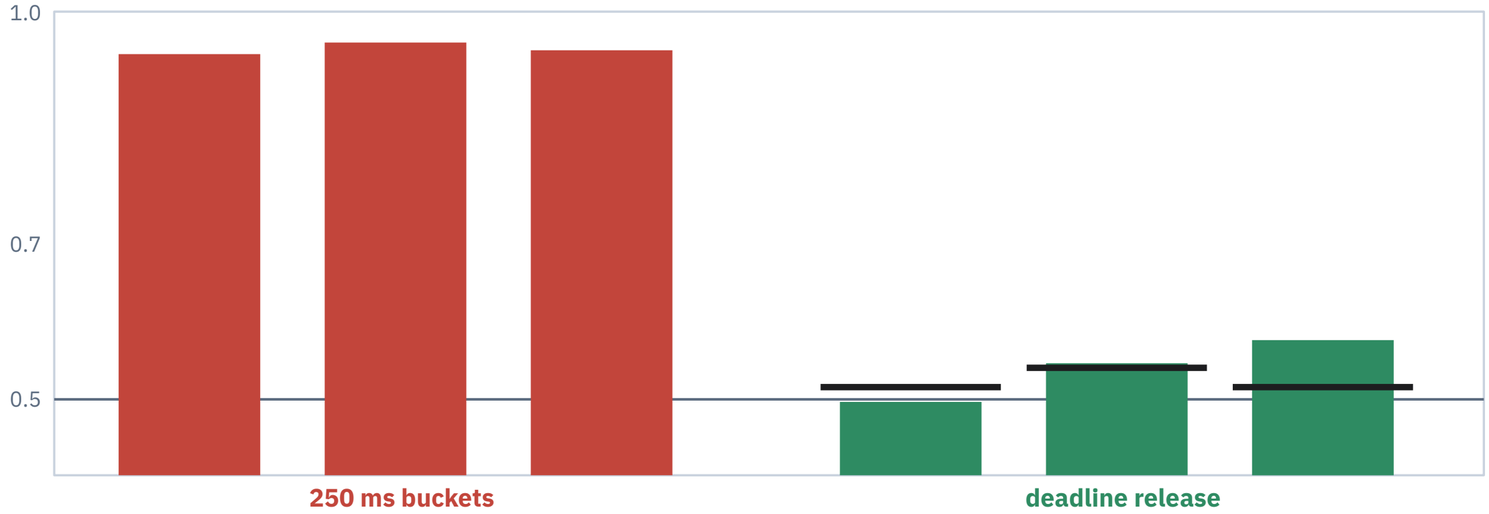
3 · Fix: deadline release

every reply leaves at t0 + D, answered or refused; a slow model is cut off and refused

default now: t0 + 1400 ms (LIVE)

stub keeps 250 ms buckets

THREE EXECUTIONS, REAL MODEL, BALANCED CLASSES **RE-MEASURED 11 Nov 2026**



250 ms buckets: accuracy 0.945/0.960/0.950, p = 0.001 in every execution: leak detected.

Deadline release: accuracy 0.495/0.545/0.575 against baselines 0.515/0.540/0.515 (black ticks); p = 0.560/0.197/0.044.

Third execution p = 0.044: below 0.05 but above the pre-declared 0.05/9 = 0.0056, so no leak detected (inconclusive as to absence). Reported as measured.

Cost (RE-MEASURED 11 Nov 2026): +519 to +621 ms per answered request; 3–8 % of model calls cut off (D per execution 1300/1400/1300 ms). **D is host- and model-specific and must be re-calibrated elsewhere.**

Code shown: finale/p4-hardening 9145592 (not yet merged into main) · every figure from finale_package/claims_used_for_finale.json

AUDIT INTEGRITY

Chained, signed, countersigned, independently verified

Hash chain
each entry carries the previous entry's hash

→ **Signed checkpoints**
Ed25519 over the chain, kept in a reviewer vault

→ **Terminal checkpoint**
binds the final entry: truncation is detectable

→ **Countersignature**
reviewer signs the terminal checkpoint (Partial)

→ **Strict verifier**
separate program; pinned key and terminal hash

verify_cli: strict, then a tampered copy (recorded 12 Nov 2026)

```
$ B=evidence/finale_p4_2026-11-11/validation/bundles/VAL-001; .venv/bin/python -m
      aegis.verify_cli --bundle $B --run-id VAL-001 --expect-state RELEASED --pubkey $(cat
      $B/broker_public_key.b64) --require-countersignature --reviewer-pubkey $(cat
      $B/reviewer_public_key.b64)
  "ok": true,
  "chain_ok": true,
  "terminal_verified": true,
  "countersignature_ok": true,
$ echo "exit code: $?"
exit code: 0
$ T=$(mktemp -d /tmp/aegis-tamper.XXXXXX); cp -r $B $T/VAL-001; sed -i "3s/\"matches_manifest\":
       true/\"matches_manifest\": false/" $T/VAL-001/audit.jsonl; diff -q $B/audit.jsonl
      $T/VAL-001/audit.jsonl
Files evidence/finale_p4_2026-11-11/validation/bundles/VAL-001/audit.jsonl and /tmp/aegis-
      tamper.gVkcKV/VAL-001/audit.jsonl differ
$ echo "exit code: $?"
exit code: 1
$ .venv/bin/python -m aegis.verify_cli --bundle $T/VAL-001 --run-id VAL-001 --expect-state
      RELEASED --pubkey $(cat $B/broker_public_key.b64) --require-countersignature --reviewer-
      pubkey $(cat $B/reviewer_public_key.b64)
  "ok": false,
  "chain_ok": false,
  "terminal_verified": true,
      "issue": "entry content does not match its hash"
  "countersignature_ok": true,
$ echo "exit code: $?"
exit code: 1
```

LIVE recorded transcript, 12 Nov 2026: strict verify, then a one-field edit of a copy

security_demo.sh step 7 (recorded 12 Nov 2026)

```
== 7. Residual risk: where the guarantee stops ==
  [LIMIT] a forger who holds the signing key AND replaces every retained copy
      produces history that verifies as consistent - NOT a success of the
      control; the signing key and the reviewer's retained copy must stay out of
       reach of whoever can edit the run directory
  [PASS] with the reviewer's countersignature required, the broker-key forgery
      is REJECTED - countersignature does not match the terminal checkpoint (re-
      signed or different history)
  [LIMIT] a forger who holds BOTH the broker key and the reviewer key (here on
      the same host) still produces history that verifies - the countersignature
       adds a second party only when the reviewer key lives off the broker host
      (python -m aegis.countersign --bundle ... on the reviewer's machine)
```

LIVE security_demo.sh step 7: a broker-key forgery and the stated limit

Tamper suite (RE-MEASURED 11 Nov 2026): 19/19 tamper categories, each detected in 30/30 trials; CLI 10/10 genuine bundles accepted, 40/40 tampered copies rejected. **Countersignature is Partial:** it stops a broker-key forgery only while the reviewer key is off the broker host.

Code shown: finale/p4-hardening 9145592 (not yet merged into main) · every figure from finale_package/claims_used_for_finale.json

HARDENING ADDED FOR THE FINALE

We closed the gaps a judge would press on, and measured each fix

F4 · user namespaces

containers never run as the key owner

container UID 900, host UIDs 525188/526212/527236/528260, errno 13 (RE-MEASURED 11 Nov 2026)

Re-encoded canaries

base64, hex, rot13, reversed, split and spelled-out forms of a foreign canary are withheld

still missed: double encoding, ciphers, paraphrase

Anomaly detectors

6 detectors in the signed log (LIVE): denial bursts, forbidden sweeps, mailbox violations, canary near-misses, cut-offs, latency drift

thresholds fixed, not tuned on adversarial traffic

Capability tokens

run-scoped, operation-scoped, at most one hour; only the reviewer mints release rights

no revocation list yet

Mailbox quotas

2,100 messages per run, 400 per 10 s, 32 MiB, 512 outbox entries (LIVE); over a limit the tenant is cut off and the run seals incomplete

Monitor side channel closed

participants see run-level events only until SEALED; no red-chosen string in the stream

cache guard: cache_prompt=true refused unless an explicit unsafe opt-in

F4 proof table (recorded 12 Nov 2026)

```
F4 proof: who runs each container (from podman top and /proc on the host)
  container                 inside     host UID (top / proc)    uid_map
  aegis-p4u-run-blue        900        527236 / 527236          0 526336 1024
  aegis-p4u-run-model       900        526212 / 526212          0 525312 1024
  aegis-p4u-run-red         900        528260 / 528260          0 527360 1024
  sandboxed model server    900        525188 / 525188          0 524288 1024
  broker (owns the signing key): host UID 1000
  guard, key directory as a mount source: refused: refusing to mount key material into a container:
      /tmp/aegis-f4.uLyvZQ/var/keys
  raw podman run, key bind-mounted read-only: errno 13 900
checks: 13/13 hold · classification: pass
```

LIVE recorded transcript, 12 Nov 2026: the F4 proof table (evaluation/p4_userns_proof.py)

Also pinned: the sandbox base image by digest; pyproject and uv.lock corrected.

Not done: gVisor or Kata (runsc not installed on the test host); key in a KMS or HSM.

Anomaly panel: the Audit page of a real-model lab run shows each detector, its threshold and its rationale (walkthrough video).

Code shown: finale/p4-hardening 9145592 (not yet merged into main) · every figure from finale_package/claims_used_for_finale.json

DEPLOYABILITY

Rootless, CPU only, offline, checked in CI, and a read-only public demo

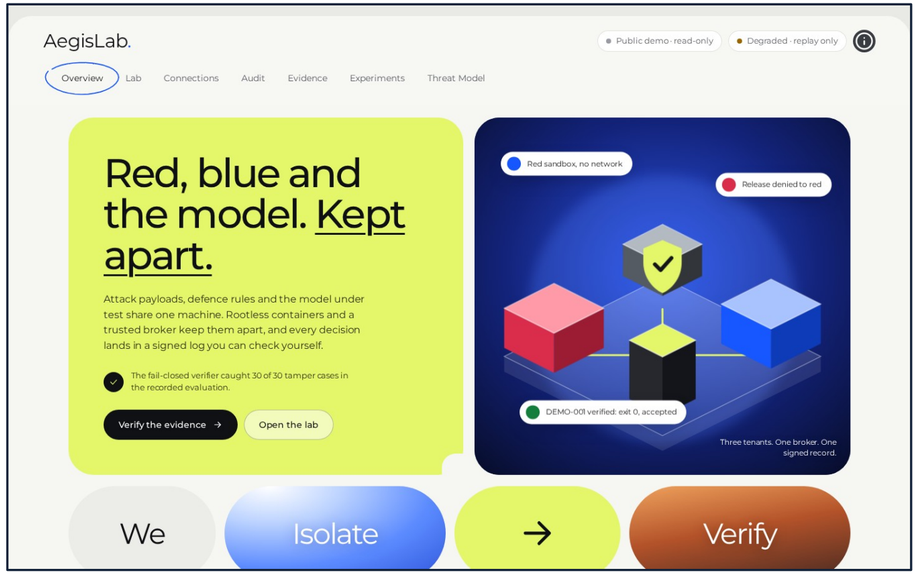
Rootless Podman
no root, no daemon; one Fedora laptop; the sandbox image pinned by digest

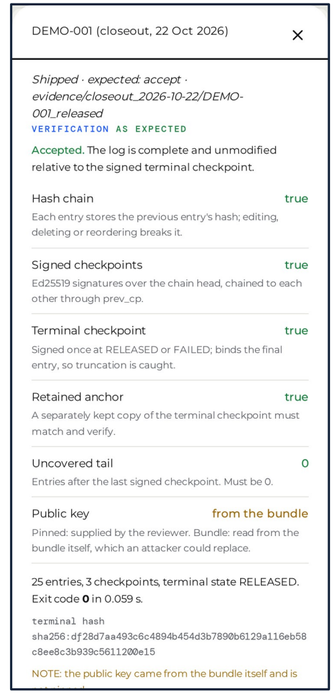
CPU only, offline
llama.cpp on CPU; the model and server binary checked by sha256; nothing downloaded at the venue

Checked, not trusted
release gates in CI on every push
702 tests passed (RECORDED 12 Nov 2026); check_claims 357/357 checks (LIVE)

Public read-only demo
aegislab.vercel.app: browse evidence, verify a bundle, tamper with a disposable copy
no operator session, no runs, no containers; rate-limited

Why read-only: a live operator console on a public URL would expose run control; it stays loopback-only.





SCREENSHOTS 12 Nov 2026, the presented code run locally with AEGIS_PUBLIC_DEMO=1: degraded mode, header 'Public demo'; phone: bundle verify accepted.

The hosted site serves origin/main until P1–P4 are merged; the verify fix is in P1.

Code shown: finale/p4-hardening 9145592 (not yet merged into main) · every figure from finale_package/claims_used_for_finale.json

RESIDUAL RISKS

What would still fail, stated before you ask

Host compromise
the signing key is a 0600 file of the host user: a kernel exploit that gains that user can forge evidence. Countersignature: Partial (reviewer key off-host only).

Anomaly thresholds not tuned
fixed, never trained on adversarial traffic: an attacker below every threshold is not flagged.

Deadline D is host- and model-specific
calibrated on one laptop for Qwen2.5-0.5B; elsewhere re-calibrate. Too short: more cut-offs. Too long: only latency.

Capability tokens
no revocation list; the API has no TLS (loopback only).

No leak detected is not absence
one classifier, one host; cache, memory-bandwidth and CPU-contention channels not measured; post-cut-off generation not measured as a channel.

Shared kernel
containers share the host kernel; gVisor and Kata not tried.

Canary detector gaps
double encoding, other bases, ciphers, homoglyphs, translation, paraphrase, a token split across replies.

Coverage
one host; one model at full scale (0.5B) plus a reduced 1.5B run; CPU only; GPU and accelerator KV-cache isolation untested.

Source: docs/finale/P4_REPORT.md section 5 and aegislab/THREAT_MODEL.md section 10.

Code shown: finale/p4-hardening 9145592 (not yet merged into main) · every figure from finale_package/claims_used_for_finale.json

FUTURE SCOPE

What we would build next, in the order the residual risks ask for it

Key custody
signing key in a KMS or HSM, rotation, a transparency log for terminal checkpoints
closes: host compromise

Semantic leak detection
paraphrase- and translation-aware detectors next to the canary scan
closes: detector gaps

Stronger sandbox
gVisor or Kata containers, one VM per tenant for high-assurance runs
closes: shared kernel

Adversarially tuned detectors
thresholds fitted on red-team traffic, with false-positive budgets
closes: untuned thresholds

GPU and accelerator isolation
KV-cache and CUDA-context tests on a GPU server, multi-slot inference servers
closes: coverage

Multi-party operation
token revocation, TLS and SSO, reviewer on a separate machine by default
closes: tokens, Partial countersignature

Not claimed: production readiness, a third-party audit, invulnerability, model robustness to prompt injection, any customer or certification.

Code shown: finale/p4-hardening 9145592 (not yet merged into main) · every figure from finale_package/claims_used_for_finale.json



AEGISLAB · TECH MAVERICKS

Isolate, measure, prove

Abdul Munaf Z
Solution architect & integration engineer

Likhith Sai N
Sandbox security & infrastructure engineer

Sreeram Rajesh
Product interface & evaluation engineer

Code and evidence: `github.com/Invinciblx777/HIH`
Read-only demo: `https://aegislab.vercel.app`

Thank you!